

UP ZERO

Projeto WhatsApp

Documentação técnica para continuidade do desenvolvimento

Arquitetura, Embedded Signup, WABAs, conexões, templates, automações, webhooks, conversas, mídia, IA, persistência e deploy.

VERSÃO 1.0 / 18 DE AGOSTO DE 2026

Objetivo do documento

Permitir que o desenvolvedor compreenda o que já está implementado, o que precisa ser preservado e quais adaptações são obrigatórias para levar o módulo de teste ao App multi-loja de produção.

Status do código documentado: build Next.js 16.3.0 concluído com 142 páginas, deployment de teste READY e rotas de WhatsApp publicadas.

01 Resumo executivo

O módulo transforma o Admin em uma central multicanal baseada na WhatsApp Cloud API.

- Conecta contas Meta, WABAs e números pelo Embedded Signup ou por configuração controlada.
- Sincroniza templates por WABA e impede que um número utilize template pertencente a outra WABA.
- Recebe eventos reais do e-commerce, aplica regras e dispara automações com idempotência e atraso.
- Recebe mensagens e status da Meta por webhook, abre a janela de atendimento e mantém uma Inbox por número.
- Permite resposta com texto, imagem, vídeo, áudio e documentos, respeitando a janela de 24 horas.
- Analisa conversas reais com IA para apontar gargalos, riscos, sinais de demanda e prioridades.
- Aplica permissões internas para visualizar, configurar, gerenciar templates e enviar mensagens.

Decisão obrigatória para a nova versão

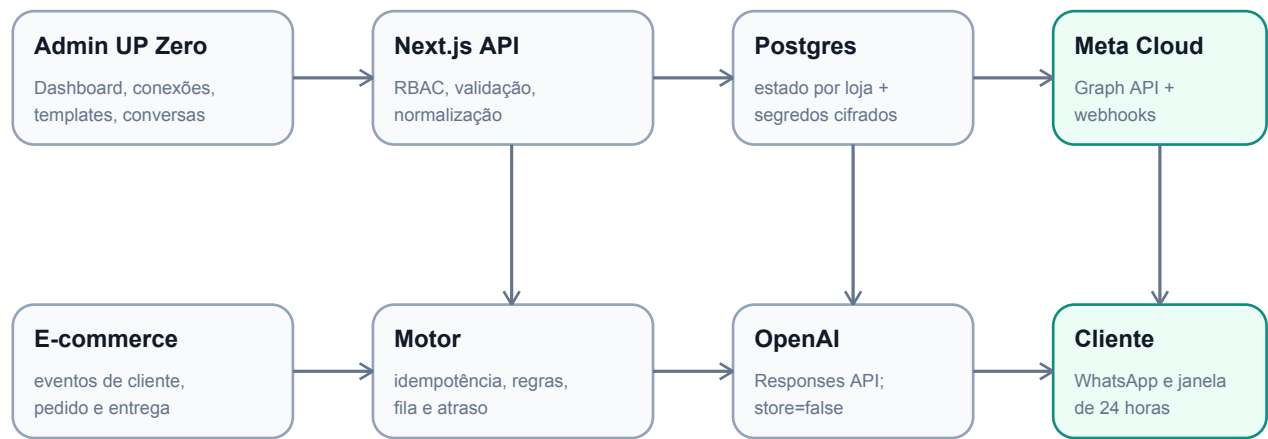
As chaves e tokens de cada cliente precisam ser cadastrados no banco do App, cifrados e vinculados ao tenant/loja. Não devem ficar hardcoded, em `NEXT_PUBLIC_*`, no `localStorage` ou em uma variável global compartilhada na Vercel.

O segredo de criptografia da plataforma permanece no servidor como variável de ambiente; os segredos dos clientes permanecem no banco, cifrados. Essa separação é essencial para isolamento multi-tenant, rotação e auditoria.

02 Arquitetura da solução

A aplicação usa Next.js App Router, APIs server-side, Postgres e integrações externas.

Fluxo lógico da solução



Todo acesso deve ser resolvido pelo tenant da sessão; nenhum segredo de cliente deve chegar ao browser.

Responsabilidades

Camada	Responsabilidade	Regra principal
Admin React	Interface de Dashboard, conexões, templates, conversas, automações e IA.	Nunca recebe tokens Meta ou a chave OpenAI salva.
Route Handlers	Autorização, validação, normalização e comunicação com provedores.	Toda mutação exige permissão e tenant da sessão.
Store/Persist	Estado funcional, revisões e segredos cifrados.	Isolamento por store_scope/tenant_id.
Meta Cloud API	WABAs, números, templates, envio, mídia e webhooks.	Template e remetente devem pertencer à mesma WABA.
OpenAI	Diagnóstico estruturado de atendimento.	Conteúdo anonimizado, store=false e BYOK por cliente.
E-commerce UP Zero	Origem de eventos de cliente, carrinho, pedido, pagamento e entrega.	Webhook autenticado, idempotente e rastreável.

03 Módulos do Admin

Navegação unificada com ícone oficial do WhatsApp em desktop e mobile.

Tela	O que faz	Dados principais
Dashboard	Métricas por período e número, produtividade, volume, resposta e análise por IA.	Conversas reais, mensagens, status e último diagnóstico.
Conexões	Embedded Signup, sincronização, seleção de fallback, saúde, registro Cloud API, webhook e exclusão persistente.	Business, WABA, Phone Number ID, qualidade e verificação.
Templates	Cards por número; sincronização; criação; variáveis {{1}}, {{2}} em ordem; payload mapping; status Meta.	Template, categoria, idioma, componentes, WABA e exemplos.
Conversas	Inbox por número com busca, janela de 24h, texto, mídia e status de envio.	Contato, mensagens, mídia, timestamp e status.
Automações	Regra por evento, número, WABA, template, condições, atraso e estratégia de remetente.	Jobs, execuções, falhas, bloqueios e métricas.

Rotas de página

- **/whatsapp**
- **/whatsapp/connections**
- **/whatsapp/templates**
- **/whatsapp/conversations**
- **/whatsapp/automations**

04 Meta, WABAs e números

O desenho considera múltiplos números e uma WABA específica para cada vendedora quando necessário.

Fluxo de conexão

- 1. Usuário inicia o Embedded Signup no Admin.
- 2. Meta autentica o usuário e retorna dados da sessão e ativos selecionados.
- 3. Servidor valida permissões, Business, WABA e Phone Number ID.
- 4. Número é registrado na Cloud API quando necessário e o webhook é inscrito.
- 5. Conexão é persistida para a loja e fica disponível em templates, conversas e automações.

Permissões Meta atualmente tratadas

Permissão	Uso
public_profile	Identificação básica do usuário que conclui o fluxo.
whatsapp_business_management	Gerenciar WABA, números e templates.
whatsapp_business_messaging	Enviar e receber mensagens pela Cloud API.
business_management	Usada pelo token de sistema em operações administrativas e descoberta de ativos.

Regra multi-WABA

A automação precisa guardar `phone_number_id` e `waba_id`. O template selecionado precisa pertencer à WABA do número emissor. Essa validação já existe e não deve ser removida.

05 Persistência atual e modelo definitivo

O protótipo usa dois registros principais no Postgres e fallback em disco apenas para desenvolvimento local.

Estrutura existente

Tabela	Chave	Conteúdo
whatsapp_state	store_scope	JSONB com integração, WABAs, números, templates, conversas, contatos, campanhas, automações, jobs, logs e IA; possui revision para controle otimista.
whatsapp_secrets	store_scope + secret_name	Ciphertext de credenciais sensíveis. A chave OpenAI do cliente usa secret_name=openai_api_key.

O que deve mudar no App de produção

- Substituir STORE_ID global por tenant_id/store_id derivado da sessão autenticada em toda requisição.
- Resolver o token Meta correto pelo tenant e pelo Phone Number ID antes de cada chamada ao Graph.
- Persistir credenciais por cliente em tabela própria, cifradas e com metadados de expiração, escopos e rotação.
- Normalizar mensagens, jobs e logs em tabelas quando o volume exigir consulta, retenção e índices eficientes.
- Manter uma trilha de auditoria sem payload sensível e sem texto integral quando não for necessário.

Modelo recomendado de credenciais

Campo	Finalidade	Observação
tenant_id / store_id	Isolamento do cliente.	Obrigatório em índices e políticas de acesso.
provider	meta, openai ou outro.	Evita colunas específicas para cada integração.
credential_type	system_user_token, openai_api_key etc.	Nome estável e auditável.
ciphertext	Segredo cifrado com AES-256-GCM.	Nunca retornar ao frontend.
key_version	Versão da chave de criptografia.	Permite rotação segura.
expires_at / scopes	Validade e permissões do token.	Usado para alertas e renovação.
created_by / updated_at	Auditoria.	Não armazenar o segredo em logs.

06 Chaves, tokens e variáveis

Separar variáveis de infraestrutura das credenciais particulares de cada loja.

Variáveis do App/Vercel

Variável	Escopo	Uso
DATABASE_URL / POSTGRES_URL	Servidor	Banco transacional do módulo.
AI_CREDENTIAL_ENCRYPTION_KEY	Servidor	Cifra as chaves OpenAI dos clientes; não pode ser rotacionada sem migração.
FACEBOOK_APP_SECRET	Servidor	Valida assinatura do webhook Meta e operações do App.
NEXT_PUBLIC_FACEBOOK_APP_ID	Público	Inicialização do SDK/Embedded Signup.
NEXT_PUBLIC_FACEBOOK_CONFIG_ID	Público	Configuração do Embedded Signup.
WHATSAPP_WEBHOOK_VERIFY_TOKEN	Servidor	Handshake de verificação do webhook Meta.
WHATSAPP_TWO_STEP_PIN	Servidor	Registro do número na Cloud API quando aplicável.
UPZERO_WEBHOOK_SECRET	Servidor	Autentica os eventos enviados pelo e-commerce.
CRON_SECRET	Servidor	Protege o processador de jobs atrasados.
APP_BASE_URL / META_GRAPH_VERSION	Servidor	Callbacks públicos e versão da Graph API.

Credenciais que devem ficar no banco do App

- Chave OpenAI informada pelo próprio cliente (BYOK).
- Token Meta de longa duração ou System User Token específico do cliente/tenant.
- Metadados de token, escopos, expiração, WABA e números autorizados.

Nunca fazer

Não usar NEXT_PUBLIC_ para tokens; não salvar chave OpenAI em state JSON, localStorage ou logs; não usar um único token Meta global para todas as lojas na versão multi-tenant.

07 Webhooks e fluxo de eventos

Existem dois webhooks independentes: Meta e e-commerce UP Zero.

Origem	Endpoint	Autenticação	Resultado
Meta	/api/mensageria/webhook	GET com verify token; POST com x-hub-signature-256 usando App Secret.	Mensagens recebidas, mídia, status sent/delivered/read/failed e atualização da Inbox.
UP Zero e-commerce	/api/mensageria/events/ecommerce	HMAC SHA-256 ou token em header/query/Bearer/body.	Normaliza evento, remove token, deduplica, agenda jobs e executa automações devidas.

Propriedades importantes do webhook de e-commerce

- Aceita event, type, event_type ou eventType e aliases conhecidos.
- Usa event_id quando fornecido; sem ID, calcula fingerprint estável do payload de negócio.
- Mantém hash do payload e limita histórico de eventos no estado atual.
- Possui dry_run=1 para validar evento e regras sem realizar envio.
- Carrinho convertido cancela jobs pendentes de carrinho criado/abandonado para o mesmo carrinho.

Eventos suportados

Cadastro/Pedido	Pedido/Entrega	Pagamento
customer.created	customer.rejected	customer.approved
customer.updated	customer.registration_incomplete	cart_created
cart_abandoned	cart_converted	order.created
order.updated	order.reserved	order.confirmed
order.payment_confirmed	order.processing	order.invoiced
order.shipped	order.delivered	order.cancelled
payment_link.created	payment_link.updated	payment_link.cancelled
payment_link.expired	payment_link.completed	payment_link.payment_failed

08 Motor de automações

Cada automação é vinculada a evento, condições, número, WABA e template.

Sequência de execução

- 1. Receber e autenticar evento.
- 2. Normalizar tipo, cliente, telefone, pedido e carrinho.
- 3. Ignorar duplicata pelo event_id/fingerprint.
- 4. Encontrar automações ativas para o tipo de evento.
- 5. Validar condições de estado, tipo de cliente, status, pagamento e valor mínimo.
- 6. Agendar job com delayMinutes ou processar quando devido.
- 7. Resolver remetente fixo, telefone da vendedora ou fallback.
- 8. Validar template APPROVED e mesma WABA do número.
- 9. Mapear {{1}}, {{2}} e demais variáveis para caminhos do payload.
- 10. Enviar pela Meta e atualizar logs, métricas, Inbox e status posteriores.

Estratégias de remetente

Estratégia	Comportamento
fixed_phone	Sempre usa o Phone Number ID definido na automação.
seller_then_fallback	Procura o seller_phone do payload entre as conexões; se não encontrar, usa o fallback.
fallback_only	Sempre usa o número de fallback configurado.

Opt-in

O motor atual não exige opt_in_whatsapp no payload para disparar automações. O aceite deve ser coletado no frontend/processo comercial e mantido como evidência de conformidade no cadastro do cliente.

09 Templates e variáveis

A interface segue a ordem numérica exigida pelo template: {{1}}, {{2}}, {{3}}.

Regras funcionais

- O usuário escolhe primeiro o número conectado; os templates são carregados no contexto da WABA desse número.
- Rodapé, texto de botão e URL são opcionais.
- Cada variável numérica é associada a um caminho de payload, por exemplo {{1}} -> customer.name.
- O mapeamento é salvo na automação/template e renderizado no momento do evento.
- Somente template APPROVED pode ser enviado; pending, rejected e paused são bloqueados.

Exemplo de mapeamento

Variável	Caminho do payload	Exemplo
{{1}}	customer.name	Victor
{{2}}	order.id	PED-10428
{{3}}	order.total	349,90
{{4}}	label.tracking_code	BR123456789

O topo do módulo exibe os campos conhecidos dos payloads com exemplo para facilitar a montagem do template. O desenvolvedor deve manter essa lista sincronizada com a documentação e os payloads reais do e-commerce.

10 Conversas, mídia e janela de atendimento

A Inbox reúne todos os números conectados e permite operação semelhante ao WhatsApp dentro das regras da Cloud API.

Capacidade	Implementação atual
Recebimento	Texto, imagem, vídeo, áudio, documento e sticker via webhook Meta.
Envio	Texto e um anexo por mensagem com legenda opcional.
Status	queued, sent, delivered, read, failed e received.
Janela	Resposta livre somente enquanto windowExpiresAt estiver aberto (24h após mensagem do cliente).
Fora da janela	UI bloqueia o composer e direciona para template aprovado.
Mídia	Upload para Meta e proxy autenticado para download/visualização; token não chega ao browser.
Limite atual	4 MB por anexo no ambiente serverless atual.

Pontos de escala

- Para anexos maiores, usar upload direto e storage controlado, evitando atravessar o corpo da Vercel Function.
- Definir política de retenção de mídia e transcrições por tenant.
- Indexar mensagens por tenant_id, phone_number_id, contact_phone e timestamp.
- Manter o download da Meta exclusivamente server-side e auditado.

11 Análises com IA e BYOK

Cada cliente pode cadastrar a própria chave OpenAI no Admin; a plataforma não precisa compartilhar uma chave global.

Fluxo seguro

- 1. Cliente informa a chave no Dashboard; o navegador envia somente por HTTPS ao backend.
- 2. Backend valida chave e modelo diretamente na OpenAI.
- 3. Chave é cifrada com AES-256-GCM usando AI_CREDENTIAL_ENCRYPTION_KEY do servidor.
- 4. Ciphertext é salvo em whatsapp_secrets, por store_scope/tenant.
- 5. Em uma análise, a chave é decifrada apenas em memória do servidor.
- 6. CPF, CNPJ, telefone, e-mail e CEP são anonimizados antes da chamada.
- 7. A requisição usa Responses API, Structured Output e store=false.
- 8. Resultado estruturado é salvo sem expor a chave ao frontend.

Saídas da análise

Bloco	Conteúdo
Score e risco	Nota de atendimento e nível low/medium/high/critical.
Resumo executivo	Síntese objetiva do período e número selecionado.
Gargalos	Evidência, impacto, severidade, métrica e ação recomendada.
Sinais de cliente	Demandas e oportunidades observadas nas conversas.
Tom	Distribuição estimada de tons e explicação.
Prioridades	Ação, responsável, prazo e impacto esperado.

Obrigatório no deploy definitivo
Cadastrar as chaves OpenAI dos clientes no banco do App, sempre cifradas e associadas ao tenant.
AI_CREDENTIAL_ENCRYPTION_KEY permanece apenas no backend; não trocar esse segredo sem um processo de recriptografia.

12 Catálogo de APIs principais

As rotas são dinâmicas e protegidas por sessão/permissão, exceto os webhooks externos autenticados por segredo/assinatura.

Método	Rota	Finalidade
GET/POST/PUT/DELETE	/api/mensageria/connections	Listar, conectar, selecionar e remover conexões.
POST	/connections/register	Registrar número na Cloud API com PIN.
POST	/connections/subscribe-webhook	Inscrever App na WABA.
POST	/connections/verify-waba	Diagnóstico do onboarding e ativos.
GET/POST	/api/mensageria/templates	Sincronizar, criar e enviar templates.
GET/POST	/api/mensageria/inbox	Listar conversas e responder com texto/mídia.
GET	/api/mensageria/media/[mediald]	Proxy autenticado de mídia Meta.
GET/POST	/api/mensageria/webhook	Handshake e eventos Meta.
POST	/api/mensageria/events/ecommerce	Receber eventos do e-commerce.
GET/POST/DELETE	/api/mensageria/automations	Gerenciar regras.
GET/POST	/automations/process	Processar jobs de automação protegidos por CRON_SECRET.
GET/PUT/POST/DELETE	/api/mensageria/ai	Configurar BYOK, analisar e remover credencial.
GET/DELETE	/api/mensageria/logs	Consultar e limpar logs conforme permissão.

13 Segurança, permissões e privacidade

A camada de segurança deve continuar sendo server-side e tenant-aware.

Permissões internas

Permissão	Permite
messaging.view	Visualizar estado, números, templates, conversas, mídia, logs e análises.
messaging.manage_settings	Conectar/remover números, configurar webhook, fallback e chave de IA.
messaging.manage_templates	Criar templates, listas, campanhas e automações.
messaging.send	Enviar mensagens, anexos, campanhas e testes.

Controles já aplicados

- Validação HMAC/timing-safe nos webhooks externos.
- Assinatura x-hub-signature-256 obrigatória no POST da Meta.
- Máscara de telefones, IDs e payloads em logs.
- Credenciais de IA cifradas com AES-256-GCM.
- Mídia acessada por proxy autenticado.
- Erro seguro com ação recomendada, sem retornar tokens.

Recomendações adicionais

- Aplicar Row-Level Security ou autorização equivalente por tenant em todas as tabelas.
- Adicionar versionamento e rotação de chaves com recryptografia transacional.
- Definir retenção, exportação e exclusão de dados conforme LGPD.
- Registrar consentimento/opt-in no App, mesmo sem exigir esse campo no webhook de automação.
- Nunca registrar corpo integral de mensagens em logs de infraestrutura.

14 Checklist de deploy da nova versão

Executar em staging antes de promover para admin.upzero.com.br.

Área	Ação obrigatória
Banco	Criar/migrar tabelas de estado, segredos e, se necessário, mensagens/jobs normalizados.
Tenant	Derivar tenant_id/store_id da sessão; remover dependência de STORE_ID global para dados de cliente.
Credenciais	Cadastrar tokens Meta e chaves OpenAI no banco do App, cifrados por tenant.
Infra secrets	Configurar DATABASE_URL, APP_SECRET, verify token, webhook secret, cron secret e encryption key na Vercel.
Meta	Atualizar Callback URL, domínio permitido, Embedded Signup e webhook do ambiente novo.
Graph	Confirmar versão da API suportada e testar sincronização de WABA, número e templates.
Cron	Configurar execução recorrente do processador de automações e autenticação por CRON_SECRET.
Permissões	Migrar/atribuir messaging.view, manage_settings, manage_templates e send aos perfis corretos.
Observabilidade	Habilitar logs de erro, alertas de webhook, filas atrasadas e taxa de falha Meta/OpenAI.
Smoke test	Executar matriz de testes abaixo com um número real e template aprovado.

Ordem recomendada

Banco e tenant -> credenciais cifradas -> Meta/URLs -> permissões -> cron -> smoke test -> promoção do domínio.

15 Plano de validação

Critérios mínimos para considerar o módulo pronto para produção.

Cenário	Procedimento	Aceite
Conexão	Embedded Signup conclui, persiste e não reaparece após exclusão.	Passou após refresh e novo login.
Webhook Meta	Mensagem recebida aparece uma vez; status progride para delivered/read.	Assinatura válida e sem duplicata.
Templates	Sincroniza status e impede template de WABA diferente.	Bloqueio explícito e log seguro.
Automação	customer.approved e order.created geram job/envio correto.	Evento idempotente; remetente correto.
Fallback	seller_phone ausente usa número preferencial configurado.	Log informa uso do fallback.
Conversa	Texto, imagem, áudio, vídeo e PDF enviam dentro de 24h.	Status e mídia aparecem na Inbox.
Janela 24h	Mensagem livre é bloqueada fora da janela.	UI direciona para template.
IA	Cliente salva chave, executa análise e remove chave.	Chave nunca reaparece; resultado usa dados reais.
RBAC	Usuário sem permissão recebe 403.	Nenhum dado ou segredo vazado.
Multi-tenant	Duas lojas não acessam dados, números ou chaves uma da outra.	Isolamento confirmado em testes automatizados.

Monitorar após o go-live

- Taxa de webhook rejeitado e latência entre Meta e Inbox.
- Jobs scheduled/processing presos e taxa de failed/blocked.
- Erros por token expirado, template inválido, pagamento ou qualidade do número.
- Custo e frequência de análises OpenAI por tenant.

16 Limitações atuais e próximos passos

Itens conscientes do protótipo que devem orientar a evolução.

Item	Estado atual	Evolução recomendada
Estado	Grande parte em JSONB por loja.	Normalizar dados de alto volume e indexar por tenant/data/status.
Jobs	Processamento por cron e array persistido.	Fila durável com retry, backoff e dead-letter queue.
Token Meta	Provider possui fallback para token de sistema do ambiente.	Resolver credencial cifrada específica do tenant/número.
Mídia	Proxy da Meta e limite de 4 MB no envio.	Storage, retenção e upload direto para volumes maiores.
Conversas	Atendimento individual, sem presença/atribuição avançada.	Fila de agentes, responsáveis, tags, SLA e histórico de transferência.
IA	Análise sob demanda do período.	Agendamento, comparação temporal, feedback humano e controle de custo.
Observabilidade	Logs funcionais no estado.	Tracing, métricas, alertas e correlação por event/message ID.

Princípio para continuidade
Preservar as validações de tenant, WABA, template, janela de 24 horas, assinatura de webhook e cifragem. Novas features devem estender essas garantias, não contorná-las.

A Referências do código

Principais arquivos para o desenvolvedor iniciar a leitura.

Área	Arquivo
UI principal	components/admin/whatsapp/whatsapp-module.tsx
Conexões/Embedded Signup	app/mensageria/whatsapp/facebook-oauth.tsx
Conversas	components/admin/whatsapp/conversations-section.tsx
Templates	components/admin/whatsapp/templates-section.tsx
Automações	components/admin/whatsapp/automations-section.tsx
IA	components/admin/whatsapp/ai-insights-section.tsx; lib/whatsapp/ai.ts
Tipos	lib/whatsapp/types.ts
Estado	lib/whatsapp/store.ts
Persistência	lib/whatsapp/persist.ts; lib/whatsapp/credentials.ts
Meta provider	lib/whatsapp/provider.ts
Motor	lib/whatsapp/automations.ts; lib/whatsapp/ecommerce-events.ts
APIs	app/api/mensageria/**/route.ts
Configuração	.env.example

Referências externas

<https://developers.facebook.com/docs/whatsapp/cloud-api>
<https://developers.facebook.com/docs/whatsapp/embedded-signup>
<https://platform.openai.com/docs/api-reference/responses>
<https://nextjs.org/docs/app>

Fim da documentação

Este documento descreve o estado do projeto em 18/08/2026. Mudanças posteriores devem atualizar o checklist, o modelo de credenciais e o catálogo de APIs.